

Flowvest

Security Review



12 May, 2026

Prepared by: Valves Security

Lead Auditors: Vesko210 | Merulez99

Contents

1 About Valves Security 3

2 Disclaimer 3

3 Risk Classification 3

4 Protocol Summary 4

5 Executive Summary 4

6 Findings 5

Medium Findings 5

[M-01] terminate couples owner refund to beneficiary transfer success, letting a
blacklisted beneficiary permanently lock the owner’s principal 5

1 About Valves Security

Valves Security is a Web3 security team founded by Veselin and Valeri. With deep experience across EVM-based protocols, Cosmos (Go) chains, and native Rust systems, we help projects identify and eliminate critical vulnerabilities. With a strong background and a strong team of freelancers we can assure a top quality audit.

Book a Security Review at valvessecurity.com or message us on X Valves Security

2 Disclaimer

The Valves team makes all effort to find as many vulnerabilities in the code in the given time period. A security audit by the team is not an endorsement of the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the implementation. We stand by our process, yet encourage follow-up audits and meaningful bug bounty incentives for continued whitehat protection.

3 Risk Classification

	Impact: High	Impact: Medium	Impact: Low
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

Impact

- High - leads to a significant material loss of assets in the protocol or a group of users
- Medium - leads to a moderate material loss of assets in the protocol, moderately harms a group of users or to some disruption of the protocol's functionality
- Low - No funds at risk

Likelihood

- High - attack path is possible with reasonable assumptions. The issue is almost certain to happen.
- Medium - only a conditionally incentivized attack vector, but still relatively likely

- Low - has unlikely assumptions or requires a significant stake by the attacker

4 Protocol Summary

Flowvest is a fixed-term, on-chain monthly payment tool for predictable stablecoin transfers.

5 Executive Summary

Overview

Project	Flowvest
Commit Hash	-
Timeline	12/05/2026 – 12/05/2026

Scope

Id	Files in scope
1	src/*

Issues Found

Critical Risk	0
High Risk	0
Medium Risk	1
Low/Info Risk	0

6 Findings

Medium Findings

[M-01] `terminate` couples owner refund to beneficiary transfer success, letting a blacklisted beneficiary permanently lock the owner's principal

Impact: Medium

Likelihood: Low

Description

In `FlowvestV1.terminate`, within the terminate window [`startAt + 60d`, `startAt + 90d`), the function pushes `amountDue` to `v.beneficiary` at L188 *before* refunding the remaining balance to `v.owner` at L199. Because both transfers occur in the same transaction, a USDC blacklist on the beneficiary atomically reverts the entire `terminate` call, and the owner can never recover their remaining principal.

This is not escapable through other paths: `release` at L150 fails for the same reason, so `amountDue` cannot be drained to 0; and after the strict `< startAt + 3 * PERIOD` check at L176, `terminate` becomes permanently unreachable. The result is a permanent lock of up to `MAX_PRINCIPAL = 3000 USDC` per vest (and up to `TVL_CAP = 20000 USDC` in aggregate), with no admin escape hatch.

Recommendation:

Decouple the beneficiary payout from the owner refund so that a failed beneficiary transfer cannot block the owner. Escrow the beneficiary's amount on transfer failure and expose a pull-based claim function: